Recap

DKIM is an authentication mechanism aimed at validating the authenticity of mail messages by digitally signing messages

DMARC introduces an additional layer of protection of mail services with respect to SPF and DKIM

It allows providers to specify guidelines for the validation, disposition and reporting of messages pretending to come from their domains

It allows receivers to improve the ways they manage mail messages

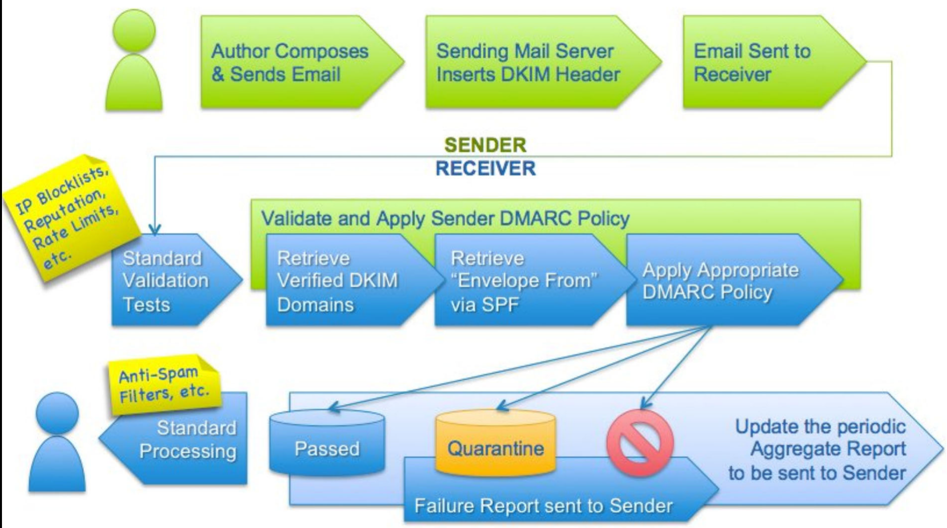
The DMARC policies associated with a domain are stored in the DNS as a record of type **`TXT`**

Examples

```
Authentication-Results: mx.google.com;
       dkim=pass header.i=@akamai.com header.s=jan2016.eng
header.b="SDPovg5/";
       spf=pass (google.com: domain of [redacted]@akamai.com
designates 2620:100:9005:57f::1 as permitted sender)
smtp.mailfrom=[redacted]@akamai.com;
       dmarc=pass (p=QUARANTINE sp=NONE dis=NONE)
header.from=akamai.com
```

```
Authentication-Results: mx.google.com;
       dkim=pass header.i=@fast.mi.it header.s=m1
header.b=xkJ9ZiG1;
       spf=pass (google.com: domain of [redacted]@3cf1e418d9f5.fast.mi.it designates 149.72.24.161 as
permitted sender) smtp.mailfrom="[redacted]@3cf1e418d9f5.fast.mi.it";
       dmarc=pass (p=REJECT sp=REJECT dis=NONE)
header.from=fast.mi.it
```

DMARC workflow



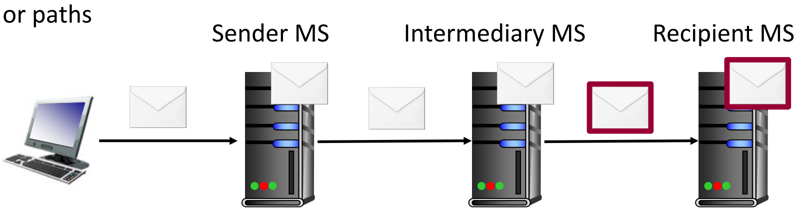
[Source: dmarc.org]

Why DMARC validation might fail

DMARC assumes that mail messages remain totally unchanged throughout the delivery process

Not every message goes directly from sender to recipient mail servers

Indirect mail flows (e.g., mailing lists, forwarding) modify message content or paths



Intermediaries between sender and recipient Mail Servers create problems because of trivial or significant changes made to messages before delivery

Authentication failures can create false positive

Authenticated Received Chain

Authenticated Received Chain (ARC) tries to overcome DMARC limitations by augmenting its authentication policy [RFC8617 "The Authenticated Received Chain (ARC) Protocol" published in July 2019]

ARC is an additional safety measure, not the primary one

It complements DMARC and provides an authenticated "*chain of custody*" for a message

Chain of custody is "*the process that tracks the movement of evidence through its collection, safeguarding, and analysis lifecycle by documenting each person who handled the evidence, the date/time it was collected or transferred, and the purpose for the transfer*" [*Source NIST*]

Chain of custody

The chain of custody of ARC is the entire set of evidence that travels with a message

Each entity that handles a message can observe the entities that handled it before and the message authentication assessment at each step

ARC preserves email authentication results across intermediaries that might modify the message

Two main features: chain validator & signature creator

Implementation

ARC introduces three new header fields

1. **`ARC-Authentication-Results`**: records the message authentication assessment, i.e., DMARC, DKIM and SPF results, as processed at message arrival time

2. **`ARC-Message-Signature`**: records a DKIM-style signature used to verify the integrity of the message [*same syntax and semantics of DKIM*]

3. **`ARC-Seal`**: records a DKIM-style signature used to verify the integrity of the **`ARC-Authentication-Results`** header field and corresponding **`ARC-Message-Signature`** header field

The recipient Mail Server checks the validity of the message using the **`ARC-Authentication-Results`** (conveyed intact by intermediaries) and the integrity of the message using the signatures included in the **`ARC-Message-Signature`** and **`ARC-Seal`** headers

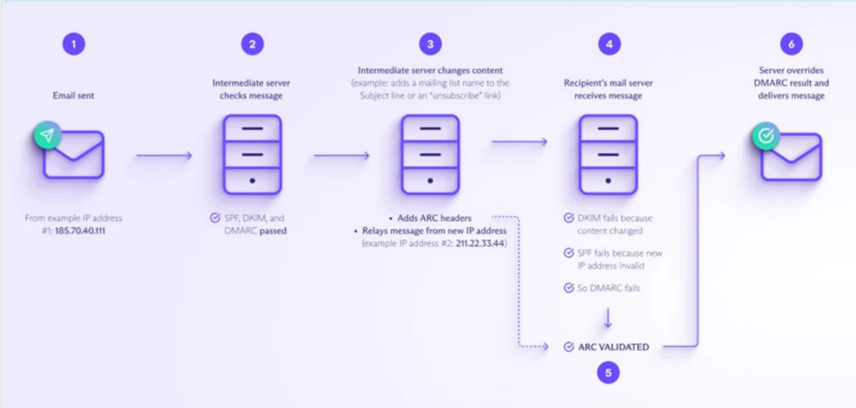
Chain validation

`ARC-Seal` header contains a tag called chain validation "**`cv=`**" which specifies the outcome of the ARC chain evaluation

Possible values:

- **`none`**: no ARC chain to validate
- **`fail`**: ARC chain validation failed
- **`pass`**: ARC chain validation succeeded

ARC implementation



Authentication outcome

sequence number

```
ARC-Authentication-Results: i=1; mx.google.com;
       dkim=pass header.i=@universitadipavia-it.20230601.gappssmtp.com
header.s=20230601 header.b=dt6DFlK0;
       spf=pass (google.com: domain of
[redacted]@universitadipavia.it designates 209.85.220.41
as permitted sender)
smtp.mailfrom=[redacted]@universitadipavia.it;
       dmarc=pass (p=NONE sp=NONE dis=NONE)
header.from=universitadipavia.it;
       dara=neutral header.i=@universitadipavia.it
```

Authentication (cont'd)

```
ARC-Message-Signature: i=1; a=rsa-sha256; c=relaxed/relaxed; d=google.com; s=arc-20240605;
        h=to:subject:message-id:date:from:mime-version:dkim-signature;
        bh=/DCwAyYaVL0UH2hGizXYDVuIOK49LZeyHxYYU7uKZMk=;
        fh=VgmKD+5q5gky0GjhokVxF/rny6uPVfd8BSAzXJ2So9Y=;
        b=hkkSU+bvif887P6Wtn5LzRrmrwg7WZadnSzDvxRn8DCn4KbgSI+lJHpUpMN8R2bTr/
         /eGfoGGxG7O6L4MBAW5UOrv9GhGPW8hRwkn9fQB8kCQIsJdj1SyCnHb0X16CA6qAVjEy
         dWeLqem/yijJixlmmrJGBehNDDnTeFU2tp+khJTHd9TB+ovUn2QHPPyWAN5vFgNIxqWj
         3ocGzGF2ILTdlupnNUBDKw7LEhVXWbeZrPDs12mZDjysYIJouCwcyHYn+LTPmWtLM+MW
         Z6Rw4G1ql4oAbQPOOmBg+loVJl70ShfZPqz9cwtb6B3UQKPI8jiu43IZFW8qS85Qcd9D
         1D5Q==;
        dara=google.com
```

chain validity

```
ARC-Seal: i=1; a=rsa-sha256; t=1741697427; cv=none;
        d=google.com; s=arc-20240605;
        b=Wr/dbhKEm67G0E3kPwYN1OmkNVz+PKbJ5uAgukESW2XsblSJoX3vaq/aUPtAsgpk7j
         KV38Wot0jGsDFxpqZNBmb7UKFzvfLlNV9+SvKBsfZesFvIBxiiw4Tm1aL4Z42FI442gC
         GhoPs3N9AGMrA6Ya5CWtWMkF2y6RwnNMXh6ipKpppWJOIW40McujWGRcGT+q+vy71Xps
         u6YprwAURQ/4cBHHOIlApUTjutnZDxPOr6a6TSFSwamJdWnEoOeioqAxkQJXIy0ggEPp
         dtTa26nuPC1qwIrFjbQAMF6imUI+7w7NVQmWbz2qz7KMmV+HowRVON6IsPOcjTYYEdT7
         91iQ==
```


Example of multi-hop message

ARC-Seal i=1; a=rsa-sha256; t=1748181141; cv=none; d=google.com; s=arc-20240605;
b=T4sQBmlJQuTJxHq+oYUE8vVYMZYPx1Y2GGy/6iwlrWr2Fj0NHj3HEY3WkS2cl6TFxE
sG6atVkj3r4OLq5niQPVtdM1UczFsHNoqVCc3EavgseamH3wTltsr64m6Wi2iXi5Es96

ARC-Message-Signature i=1; a=rsa-sha256; c=relaxed/relaxed; d=google.com; s=arc-20240605;
h=content-transfer-encoding:subject:from:to:content-language :user-agent:mime-version:date:message-id:dkim-signature;
bh=GrfGSE3vqvnxglaMXKd6UimKGEBmgCEoAse+ENzRy6o=;

ARC-Authentication-Results i=1; gmr-mx.google.com; dkim=pass header.i=@unipv-it.20230601.gappssmtp.com header.s=20230601 header.b="nHH/+UeJ"; spf=pass (google.com: domain of [redacted]@unipv.it designates 2a00:1450:4864:20::52e as permitted sender) smtp.mailfrom=[redacted]@unipv.it; dmarc=pass (p=NONE sp=NONE dis=NONE) header.from=unipv.it; dara=pass header.i=@googlegroups.com

Second & third hop

ARC-Authentication-Results	i=2; gmr-mx.google.com; dkim=pass header.i=@unipv-it.20230601.gappssmtp.com header.s=20230601 header.b="nHH/+UeJ"; spf=pass (google.com: domain of [redacted]@unipv.it designates 2a00:1450:4864:20::52e as permitted sender) smtp.mailfrom=[redacted]@unipv.it; dmarc=pass (p=NONE sp=NONE dis=NONE) header.from=unipv.it; dara=pass header.i=@googlegroups.com

ARC-Authentication-Results	i=3; mx.google.com; dkim=pass header.i=@googlegroups.com header.s=20230601 header.b=eHn7F4aK; arc=pass (i=2 spf=pass spfdomain=unipv.it dkim=pass dkdomain=unipv-it.20230601.gappssmtp.com dmarc=pass fromdomain=unipv.it); spf=pass (google.com: domain of [redacted]@googlegroups.com designates 209.85.220.55 as permitted sender) smtp.mailfrom=[redacted]@googlegroups.com; dmarc=fail (p=NONE sp=NONE dis=NONE arc=pass) header.from=unipv.it; dara=fail header.i=@unipv.it

Final hop

ARC-Authentication-Results	i=4; mx.google.com; dkim=pass header.i=@googlegroups.com header.s=20230601 header.b=eHn7F4aK; arc=pass (i=2 spf=pass spfdomain=unipv.it dkim=pass dkdomain=unipv-it.20230601.gappssmtp.com dmarc=pass fromdomain=unipv.it); spf=pass (google.com: domain of [redacted]@googlegroups.com designates 209.85.220.55 as permitted sender) smtp.mailfrom=[redacted]@googlegroups.com; dmarc=fail (p=NONE sp=NONE dis=NONE arc=pass) header.from=unipv.it; dara=fail header.i=@unipv.it

Resource Record

Domain owners use the DNS to store the public key associated with ARC

Resource Record of type **`TXT`** in a dedicated domain name, i.e., **`selector._domainkey.domain-name`**

DNS query to obtain the public key (performed at each hop)


```
arc-20240605._domainkey.google.com. 3600 IN TXT "k=rsa;
p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAl3xpv8nzv4
8sGAt6yT3BhDpQcLv9Cgnot1arQefERmoFpgygBi73YM3l1lM3fb435Q
Bz8Qsu3ZM+xkIM5+UM9p286xJXI/26vNSbCFEAHeYJmUCJMUP1sX1b5o
KzW5NJgojoJNLRulyo6GC6nFpBLv6j2hL41GOjg+RdYDxrTcQavsP2DM
QLFP/mdsg7zBlfY" "dg0occfvpJXHYgxN3M1mYvBvbmnmPIrMtfoMFD
dmJCiri3c9X9je2yz/gcpKXoz0n+O9Clk8jVQkrPEcahkCHPpbe662VL
ndAYsiD36IyF0+shLOJn0duf2O5eMNlUBwMPX7N589dz3Xy32B0eoPQI
DAQAB"
```


More details

The standard does not specify how the entities handling the messages should interpret or utilize ARC results in making decisions about message disposition

ARC cannot replace DMARC

ARC does not provide any information about the reputation or trustworthiness of the sender or the intermediaries (e.g., intermediaries could add malicious content or remove ARC headers)

Google has been very active in pushing ARC

ARC is currently supported by most commercial MTAs and mailing list managers